SECURESCAN

SÉCURISEZ VOTRE CODE EN UN CLIC

AZAG Dillon
MARGARIAN Diana
NGUYEN Thi Van Anh

PLAN

Contexte & Problématique

Solution proposée – SecureScan

Architecture & Choix techniques

Fonctionnalités clés

Démonstration

Conclusion & Perspectives

LE CONTEXTE & LE PROBLÈME

CyberSafe Solutions souhaite détecter automatiquement les vulnérabilités du code source.

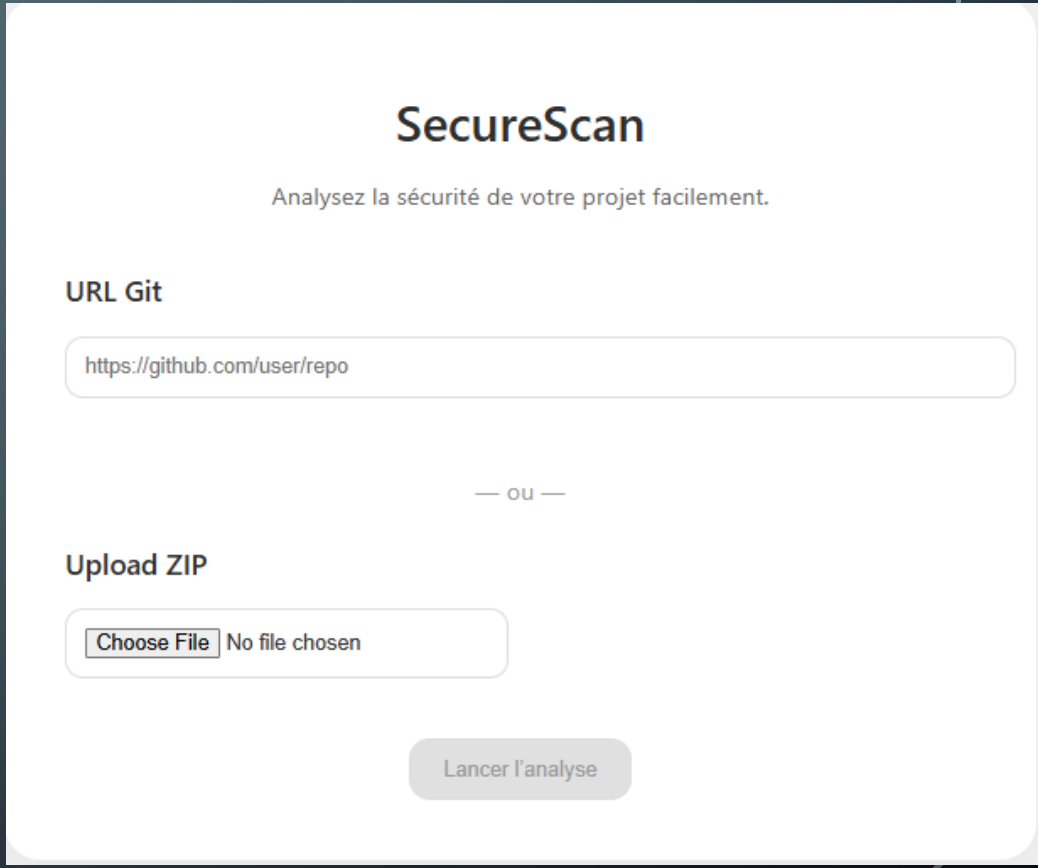
Problèmes actuels :

- Aucun scan sécurité centralisé
- Failles injection non détectées avant production
- Dépendances vulnérables
- Corrections manuelles lentes

OBJECTIF DU PROJET

Développer une plateforme qui permet :

- Analyse sécurité automatisée
- Mapping vers OWASP Top 10
- Système de correction assistée
- Génération de rapport



CHOIX TECHNOLOGIQUES

Expérience utilisateur fluide

- Performance élevée
- Support natif de l'asynchrone

- Données relationnelles complexes
- Fiabilité et robustesse

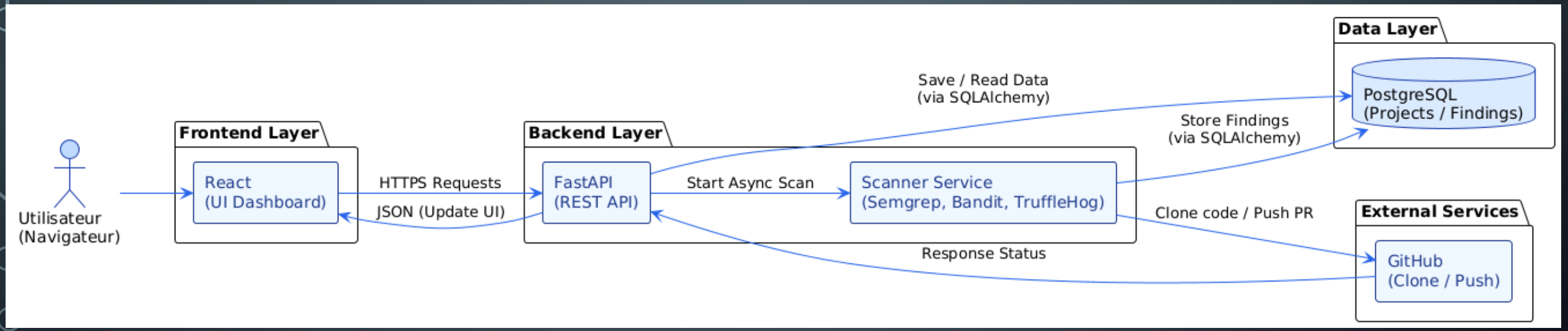
LES MOTEURS D'ANALYSE

SAST

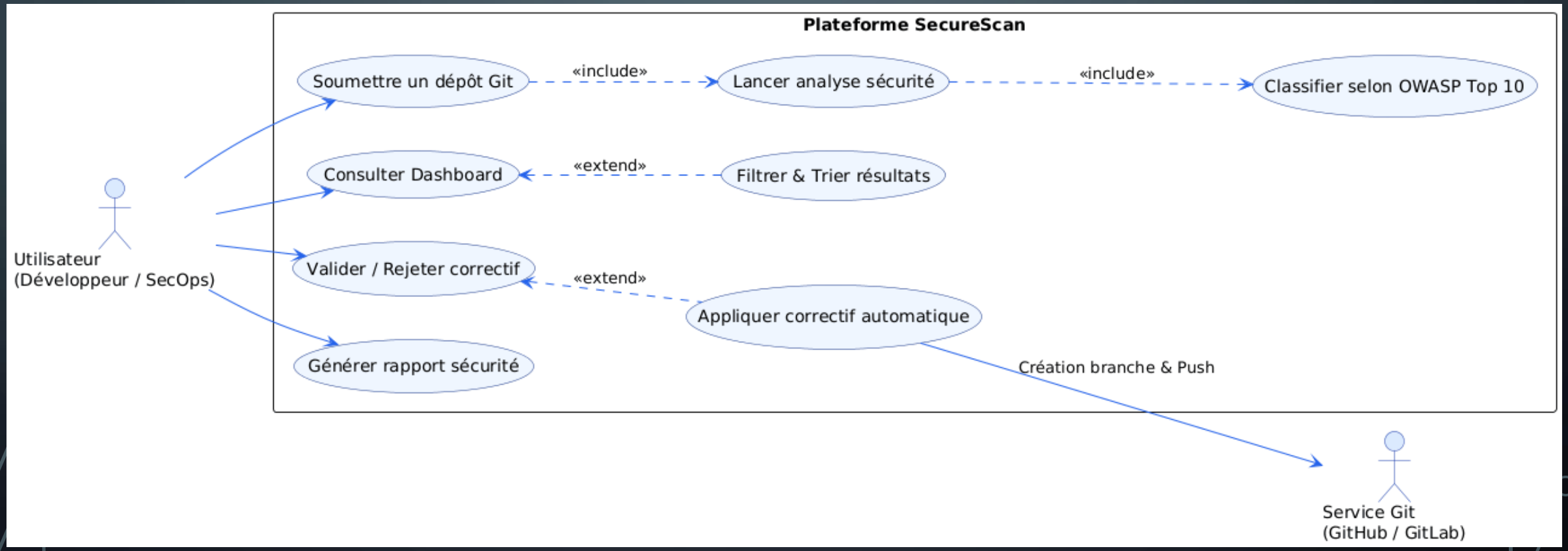
Qualité - Python

TruffleHog - Secrets

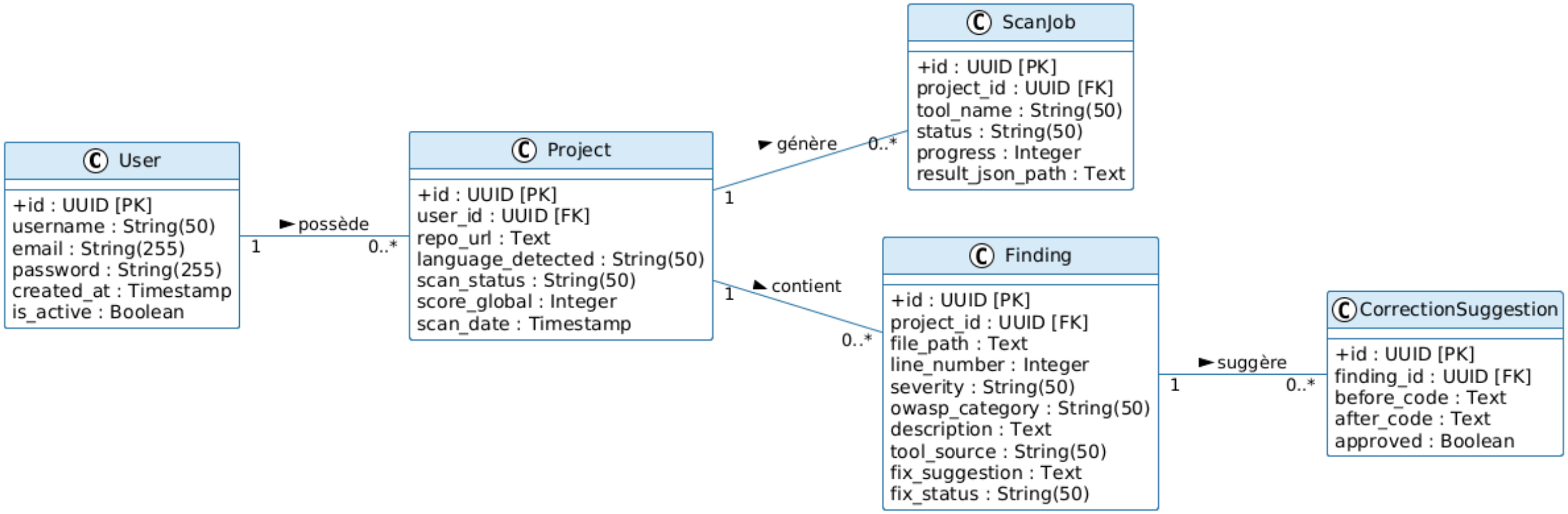
ARCHITECTURE GLOBALE



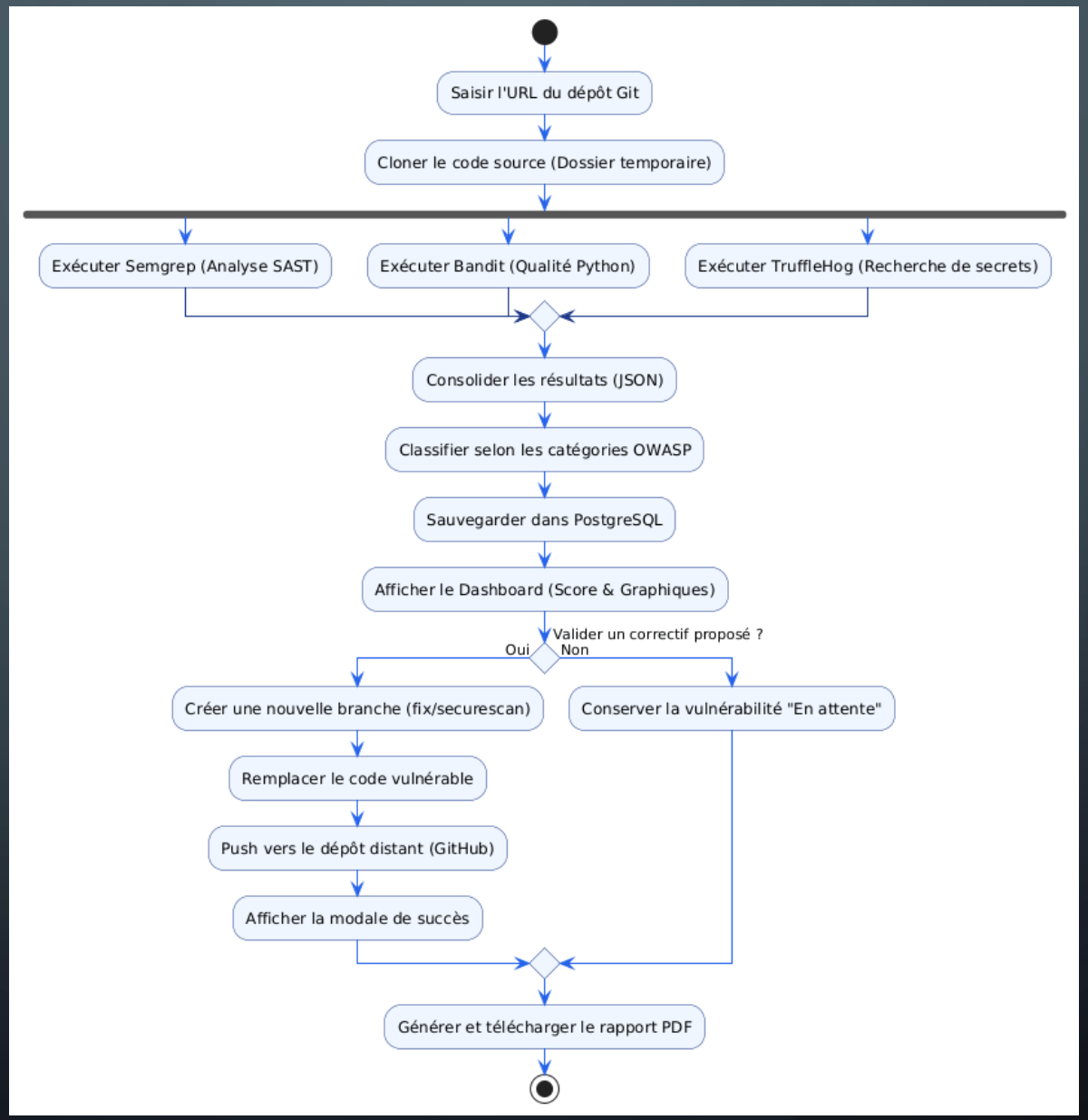
USE CASE


Plateforme SecureScan
Soumettre un dépôt Git
«include»
Lancer analyse sécurité
«include»
Classifier selon OWASP Top 10
Consulter Dashboard
«extend»
Filtrer & Trier résultats
Utilisateur
(Développeur / SecOps)
Valider / Rejeter correctif
«extend»
Appliquer correctif automatique
Générer rapport sécurité
Création branche & Push
Service Git
(GitHub / GitLab)

MODÈLE DE DONNÉES



WORKFLOW D'EXÉCUTION



CLASSIFICATION OWASP TOP 10

Outil	Détection brute	Catégorie OWASP 2025
Semgrep	Faille SQL (CWE-89) / XSS	A05:2025 - Injection
Semgrep	Faille SSRF / Contrôle d'accès	A01:2025 - Broken Access Control
Bandit	Mots de passe codés en dur	A07:2025 - Authentication Failures
Bandit	Blocs try/except vides (Fail-open)	A10:2025 - Mishandling of Exceptional Conditions
TruffleHog	API Keys / Secrets exposés dans Git	A02:2025 - Security Misconfiguration

LE DASHBOARD

Dashboard

Voir corrections

Score global

3 vulnérabilité(s) affichée(s) (sur 3)
Version Semgrep : 1.136.0

69/100

Bandit
0
issue(s) détectée(s)

TruffleHog
1
secret(s) détecté(s)

Vulnérabilités détectées

Toutes les sévérités | Toutes les sources | Toutes les catégories OWASP | Réinitialiser

Titre	Sévérité	OWASP	Fichier	Ligne
› Generic Secret detected	High	A07	AppSymfonyPress_DianaMargarian/symfonypress/.env:2	2
› Using user input when deleting files with `unlink()...	Medium	A01	… ianaMargarian/symfonypress/src/Controller/AdminArticleController.php:107	107
˅ High Entropy	High	—	AppSymfonyPress_DianaMargarian/symfonypress	—

Description détaillée :
High Entropy

Outil source :
✓ **TruffleHog**

LE CŒUR DU PROJET : L'AUTO-FIX

Corrections & Rapport

Sélectionne des corrections à appliquer, puis génère un rapport.

Appliquer corrections | Télécharger rapport | Retour dashboard

Corrections appliquées (demo).

Corrections proposées

Sélectionnées : **1** / 2

generic.secrets.security.detected-generic-secret.detected-generic-secret — A07 — High

Fichier : `…000gn/T/tmpet7a909s/project/AppSymfonyPress_DianaMargarian/symfonypress/.env:2-2`

Avant	Après
`requires login`	`(pas de fix automatique — à corriger manuellement)`

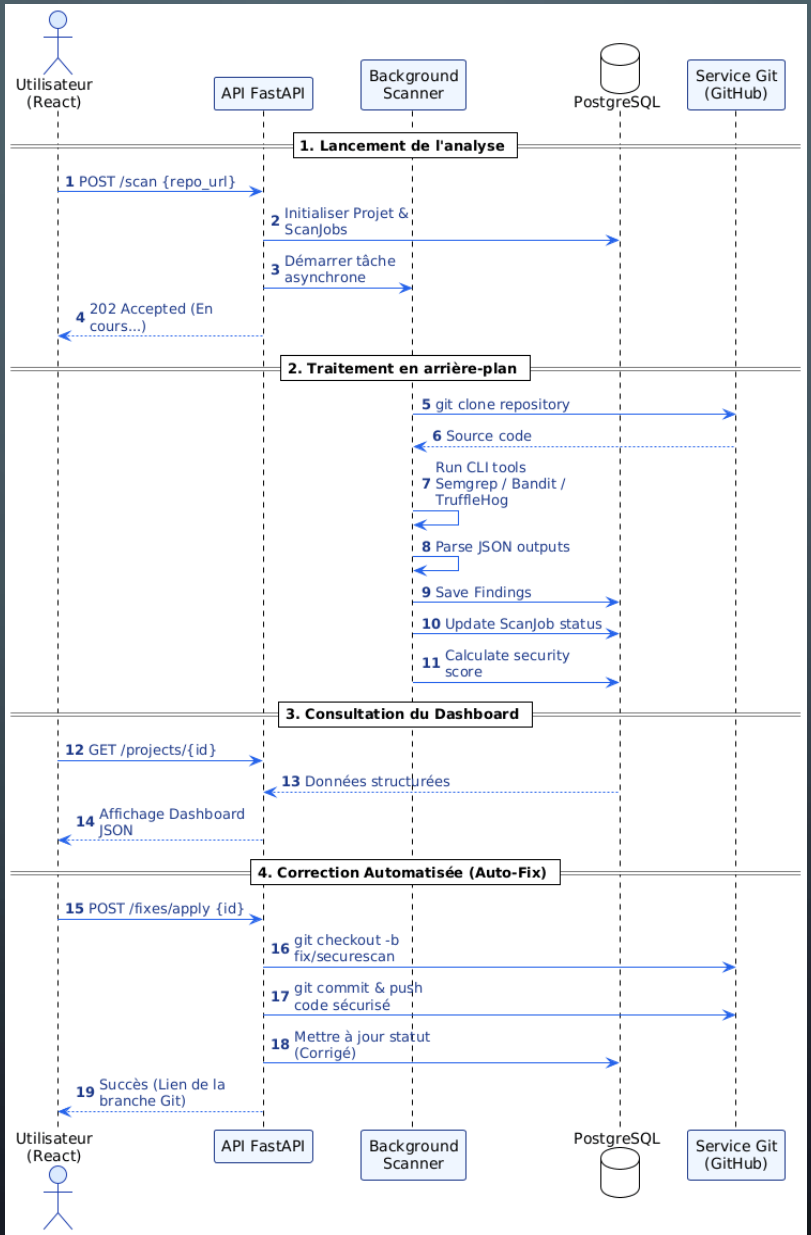
Suggestion: corriger manuellement / créer une PR.

php.lang.security.unlink-use.unlink-use — A05 — Medium

Fichier : `…ss_DianaMargarian/symfonypress/src/Controller/AdminArticleController.php:107-107`

Avant	Après
`requires login`	`(pas de fix automatique — à corriger manuellement)`

INTÉGRATION GIT AUTOMATISÉE



GÉNÉRATION DU RAPPORT

SÉCURITÉ "BY DESIGN"

- Variables `.env` cachées
- Nettoyage des `temp_repos`
- Commandes CLI sécurisées (Pas de `shell=True`).
- Validation input URL
- Limitation taille repository
- Timeout protection

IMPACT BUSINESS

- Gain de temps (analyse automatique)
- Réduction des risques
- Amélioration conformité sécurité

DÉMO LIVE

FONCTIONNALITÉ FUTUR

Mistral AI

MERCI POUR VOTRE ATTENTION !

SECURESCAN : CODEZ EN PAIX